

해외 법제 동향

미국 CISA, 위험 기반 보안 업데이트 우선순위 지정 지침(BOD 26-04)
발표 ('26.6.10)

○ 개요 및 추진배경

- 미국 사이버보안 및 인프라보호청(CISA)은 연방민간행정부기관(FCEB)*의 취약점 관리를 강화하기 위하여 '위험 기반 보안 업데이트 우선순위 지정 지침(BOD 26-04: Prioritizing Security Updates Based on Risk)'을 발표 ('26.6.10)

* (Federal Civilian Executive Branch) 미국 연방 행정부 중 국방부 및 정보기관을 제외한 연방정부 부처 및 기관

- CISA는 최근 트럼프 행정부가 발표한 '첨단 인공지능 혁신 및 보안 촉진에 관한 행정명령(EO 14409)'에 명시된 연방민간행정부 정보 시스템의 사이버 방어 추진을 이행하기 위해 법적 구속력이 있는 지침을 마련

첨단 인공지능 혁신 및 보안 촉진에 관한 행정명령 (EO 14409)

제2조 첨단 AI를 위한 미국 시스템의 업그레이드

(C) 이 명령 발표일로부터 30일 이내에, 국토안보부 장관은 사이버보안 및 인프라 보안청장을 통해, 관리예산국(OMB) 국장, 대통령 국가안보 담당 보좌관 및 국가 사이버 담당관과 협의하여, 다음을 수행하기 위해 적절한 구속력 있는 운영 지침 및 기타 지침을 발표해야 한다:

- (i) 국가의 주요 기능을 보호하기 위해 연방민간행정부 정보 시스템의 사이버 방어를 신속하게 추진하고 우선순위를 부여할 것

- 동 지침은 기존 '알려진 악용 취약점(KEV)'의 중대한 위험 감소 지침(BOD 22-01, '21. 11)'을 발전시켜 각 기관이 ▲자산의 공개 노출, ▲알려진 악용 취약점 식별, ▲취약점 악용 자동화 가능 여부, ▲기술적 영향 등을 고려하여 최고위험 취약점에 대한 조치를 우선순위로 지정하고 적시에 대응하도록 규정

○ 주요내용

- (정의) 동 지침은 자산, 공개 노출, 부분적 제어, 완전한 제어 등 주요 용어를 다음과 같이 정의

구분	주요내용
자산(Asset)	• 정보 시스템을 구성하는 하드웨어 또는 소프트웨어 항목
공개 노출 (Publicly exposed)	• 기관이 소유하거나 관리하는 모든 IT 자원으로서 물리적 또는 논리적 위치와 관계없이 인터넷과 같은 공용 네트워크를 통해 인증되지 않은 주체나 신뢰할 수 없는 주체가 접근할 수 있는 상태
부분적 제어 (Partial control)	• 위협행위자가 익스플로잇을 통해 완전한 제어권을 확보할 수 있는 확률적 기회가 매우 낮은 경우 ※ '매우 낮음'이란 위협 행위자가 물리적 또는 보안상의 장애물을 극복하고 완전한 제어권을 확보하기 위해 합리적으로 충분한 시도를 할 수 없는 상태
완전한 제어 (Total control)	• 위협 행위자가 익스플로잇을 통해 소프트웨어의 동작을 완전히 제어할 수 있고 로그인 자격 증명을 확실하게 노출시키는지 여부도 포함

- **(적용범위)** 동 지침은 예산관리처 회람(OMB Circular) A-130(Management of Federal Information Resources)에서 ‘연방 정보 시스템’으로 정의하는 모든 기관의 자산에 적용되고, 연방민간행정부기관은 모든 조달 계약을 검토하여 동 지침의 요구사항을 준수하기 위해 필요한 수정사항을 결정해야 함

* **(연방 정보 시스템)** 기관 또는 기관을 대신하여 다른 주체가 사용하거나 운영하는 정보 시스템으로서, 기관 정보를 수집, 처리, 저장, 전송, 배포하거나 기타 방식으로 유지하는 시스템을 의미

- **(필수 조치사항)** 연방민간행정기관은 동 지침 발표일로부터 즉시 취약점 관리 정책 등을 검토 및 갱신해야 하고, 60일 이내에 일반 공개 취약점(CVE) 데이터베이스 및 KEV 카탈로그* 기반으로 취약점 관리 절차를 개선해야 하며, 180일 이내에 취약점을 수정하고 외부 접근 가능한 모든 기관의 자산을 지속적으로 식별해야 함

* **(Known Exploited Vulnerabilities catalog)** CISA에서 운영하는 실제 악용된 취약점 목록으로, 일반 공개 취약점(CVE) 중에서 해커가 실제로 공격에 활용하고 있는 사례만 엄선하여 등록하는 공식 카탈로그

〈 단계별 필수 조치사항 주요내용 〉

구분	주요내용
1단계 (즉시)	• 취약점 관리 정책을 검토·갱신하고, CISA의 요청 시 정책 및 절차의 사본을 제공해야 함 - KEV 카탈로그 내 취약점에 대한 지속적인 시정 조치 및 내부 검증 절차, CISA 보고 체계 등을 포함 • KEV 카탈로그의 업데이트를 모니터링하고, CMD 대시보드*를 활용한 보고 체계 자동화 * (Continuous Diagnostics and Mitigation) CISA가 연방 정부기관의 네트워크 보안상태를 실시간으로 모니터링하고 방어할 수 있도록 제공하는 중앙집중식 통합 보안 정보 시스템
2단계 (60일 이내)	• CVE 데이터베이스 및 KEV 카탈로그 기반으로 취약점 관리 프로세스 업데이트, CISA 요청 시 갱신된 정책 및 절차 제출
3단계 (180일 이내)	• 모든 취약점을 명시된 일정(최고위험 취약점은 3일 이내, 고위험 취약점은 14일 이내, 저위험 취약점은 60일 이내) 내에 수정해야 함 - 특히 ▲자산의 공개 노출, ▲악용 가능한 취약점 식별, ▲취약점 악용 자동화 가능 여부, ▲기술적 영향 등을 기반으로 위험도가 가장 높은 취약점은 3일 이내에 수정 또는 완화 조치를 이행하고 포렌식*을 수행 * (Forensic Triage) 기관이 3일 이내에 취약점 수정 또는 완화 조치를 완료하고, 시스템 침해 여부를 신속히 평가하기 위해 자산에 대하여 최소한의 디지털 포렌식을 수행하는 절차 • 외부 접근 가능한 자산을 지속적으로 식별 및 태깅해야 함

○ 전망 및 시사점

- 트럼프 행정부는 고도화되는 AI기술이 초래하는 새로운 국가안보 및 사이버보안 위협에 대응하기 위하여, 공공·민간 부문의 정보 시스템을 현대화하고 외부 위협에 적시 대응하는 ‘첨단 인공지능 혁신 및 보안 촉진에 관한 행정명령(EO 14409)’을 통해 CISA가 연방정부 내 정보 시스템의 사이버 방어를 추진하도록 지시
- 최근 사이버 위협 행위자들이 AI를 활용하여 패치가 출시되기 전 취약점을 악용하는 사례가 증가함에 따라 CISA는 취약점 관련 연방정부의 사이버보안 관행을 현대화할 수 있는 조치가 필요함을 강조

- 이에, CISA는 ‘위험 기반 보안 업데이트 우선순위 지정 지침(BOD 26-04)’을 발표하여, 자산의 공개 노출, 알려진 악용 취약점 식별, 취약점 악용 자동화 가능 여부, 기술적 영향 등을 기반으로 연방정부 전반의 취약점 대응 및 관리를 강화
 - 특히, 상기 네 가지 기준을 모두 충족하는 최고위험 취약점은 3일 이내에 수정 또는 완화 조치를 수행하고 자산의 시스템 침해 여부를 평가(Forensic Triage)하도록 함
- CISA는 3일 이내 취약점 수정 조치의 현실 가능성을 파악하기 위해 일부 대규모 연방기관을 사전 분석한 결과, 전체 취약점의 1%만이 3일 이내 조치 대상에 해당하고 60%는 차기 시스템 업그레이드 시점까지 연기 가능한 것으로 확인되어 핵심 고위험 취약점에 자원을 집중하는 것이 중요함을 강조
- 다만, CISA의 전(前) KEV 부서장이었던 토드 비어즈리(Tod Beardsley) 대표는 “100개 이상의 기관이 3일 안에 취약점을 수정하는 것이 가능할지 의문”이라며 정책 실효성에 대한 우려를 제기
- 한편, 국내에서는 최근 과기정통부가 ‘AI기반 사이버위협에 대응하기 위한 민간 정보보호 추진계획’을 발표(‘26.5.29)하여 AI 취약점 공개에 대응하기 위한 민관합동 대응체계를 구축하고, 한국인터넷진흥원 내 취약점 관리센터 중심으로 패치관리 일원화 및 긴급대응을 준비하며, 피해 파급력이 큰 주요기업 대상으로 보안점검 등을 시행하는 정책을 추진하기로 함

Reference

- <https://www.cisa.gov/news-events/directives/bod-26-04-prioritizing-security-updates-based-risk>
- CyberScoop, CISA directive orders agencies to prioritize vulnerability patching in a new way, (‘26.6.10.)
- Industrial Cyber, CISA BOD 26-04 directs agencies to prioritize exploited vulnerabilities and assess compromise before patching, (‘26.6.11.)
- Nucleus Security, Understanding and Navigating the Requirements of CISA BOD 26-04, (‘26.6.18.)
- 과학기술정보통신부, AI기반 사이버위협에 대응하기 위한 민간 정보보호 추진계획(안), (‘26.5.29)

인터넷·정보보호 법제 동향

(2026년 6월)

| 발 행 처 | 한국인터넷진흥원

(58324) 전라남도 나주시 진흥길 9 한국인터넷진흥원

Tel. 1433-25

| 기획·편집 | 법제연구팀

| 발간·배포 | www.kisa.or.kr

※ 본 자료의 내용은 한국인터넷진흥원의 공식 견해를 나타내는 것은 아닙니다.

※ 본 자료 내용의 무단 전재 및 상업적 이용을 금하며, 가공·인용할 때에는 반드시 출처를 밝혀 주시기 바랍니다.